⬡ PORTSWIGGER WEB SECURITY ACADEMY · PRACTITIONER

Password Brute-Force via Password Change

- Tool: Burp Suite Community
- Category: Authentication
- Steps: 11
- Solved ✓

📋 LAB OVERVIEW

This lab's password change functionality is vulnerable to brute-force attacks. The goal is to exploit the difference in error messages returned by the change-password form to enumerate Carlos's password from a known candidate list — without triggering account lockout.

YOUR CREDENTIALS	VICTIM USERNAME	ATTACK TOOL
wiener : peter	**carlos**	**Burp Intruder**

PASSWORD FOUND
batman

01 Read the Lab Description

Open the lab and review the objective. You are given credentials `wiener:peter` and told to brute-force the account of victim user **carlos** using the candidate password list provided.

step01.png — Lab description

Lab: Password brute-force via password change

PRACTITIONER

LAB Not solved

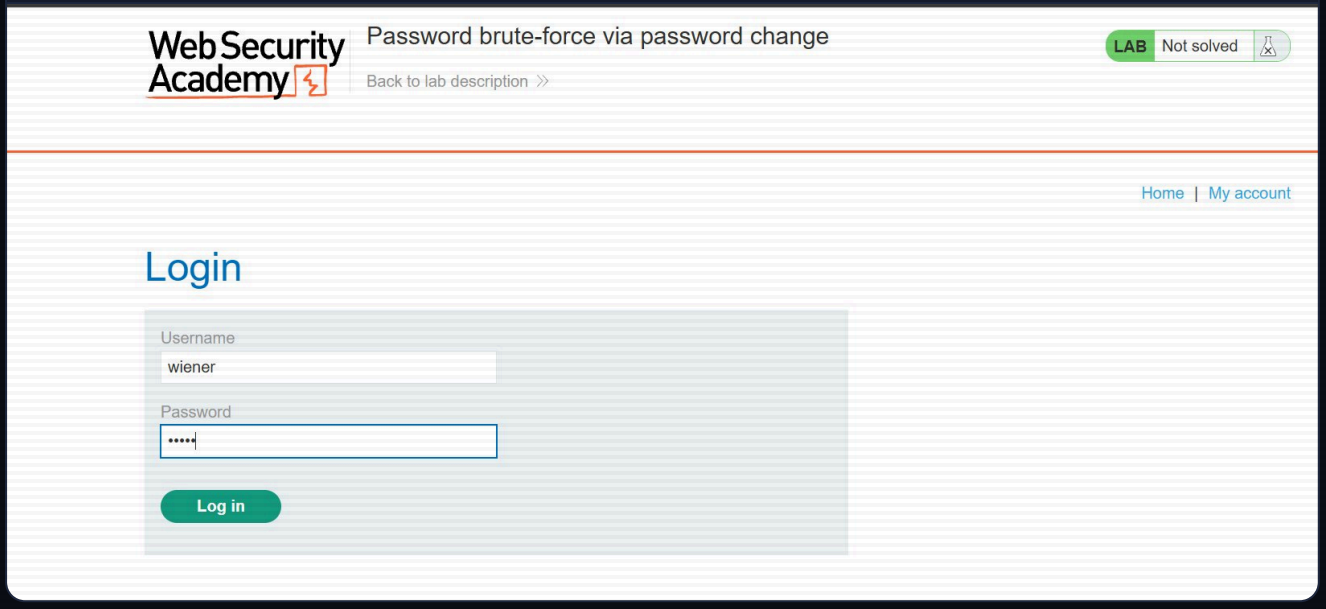
This lab's password change functionality makes it vulnerable to brute-force attacks. To solve the lab, use the list of candidate passwords to brute-force Carlos's account and access his "My account" page.

- Your credentials: `wiener:peter`
- Victim's username: `carlos`
- Candidate passwords

02 Log In as Wiener

Navigate to the login page and sign in with your own account using `wiener` as the username and `peter` as the password. This gives you access to the password change functionality.

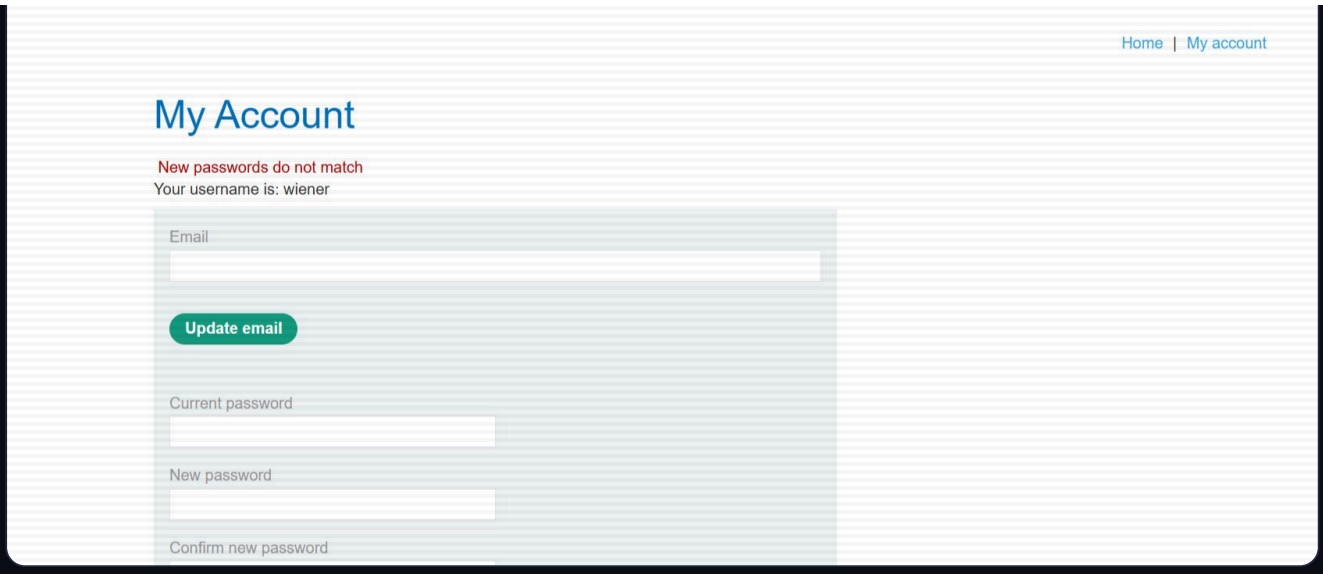
step02.png — Logging in as wiener



03 Observe the "New Passwords Do Not Match" Error

On the My Account page, deliberately submit the password change form with a **correct current password** but two **mismatched new passwords**. Notice the error message: `New passwords do not match`. This will be used as our Grep-Match signal in Burp Intruder.

step03.png — "New passwords do not match" error

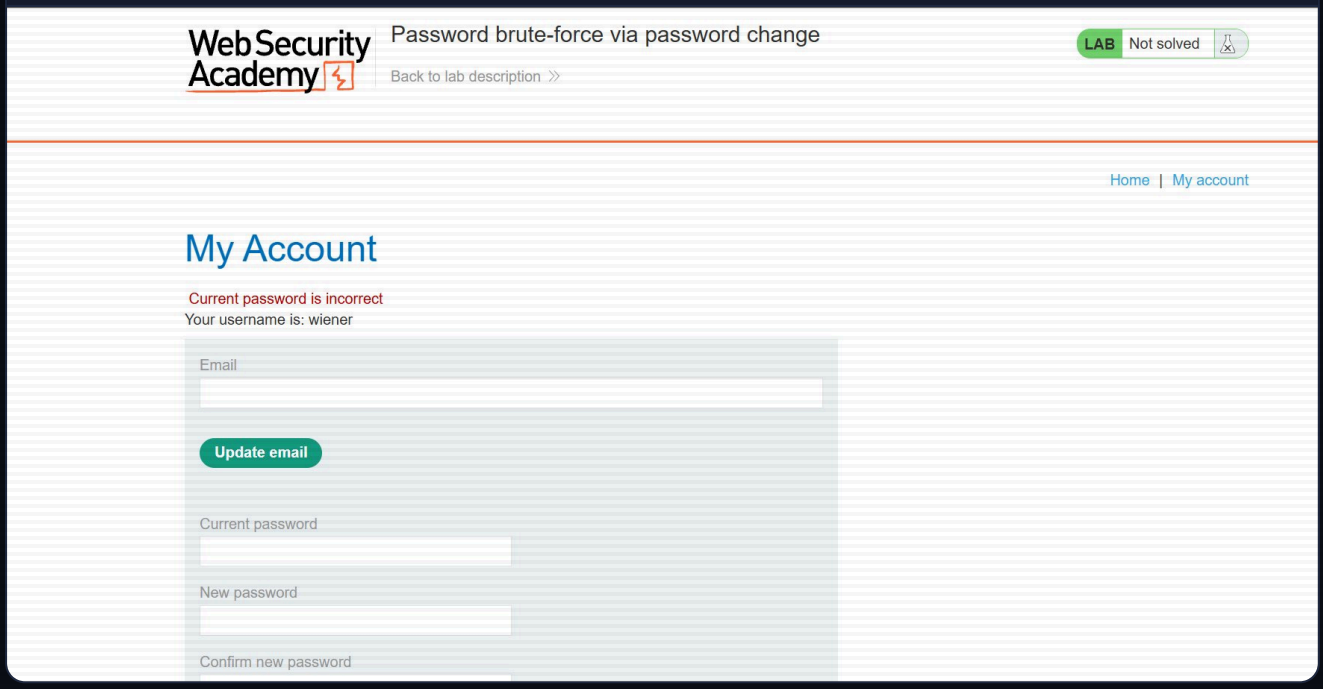


🔍 **Key Observation:** When the current password is *correct* but new passwords mismatch, the server returns `New passwords do not match`. When the current password is *wrong*, it returns a different message — `Current password is incorrect`. This difference is the oracle we exploit.

04 Observe the "Current Password Is Incorrect" Error

Now submit the form with a **wrong current password** and mismatched new passwords. The server responds with `Current password is incorrect`. This confirms the two distinct response states we need to distinguish correct vs incorrect passwords.

step04.png — "Current password is incorrect" error

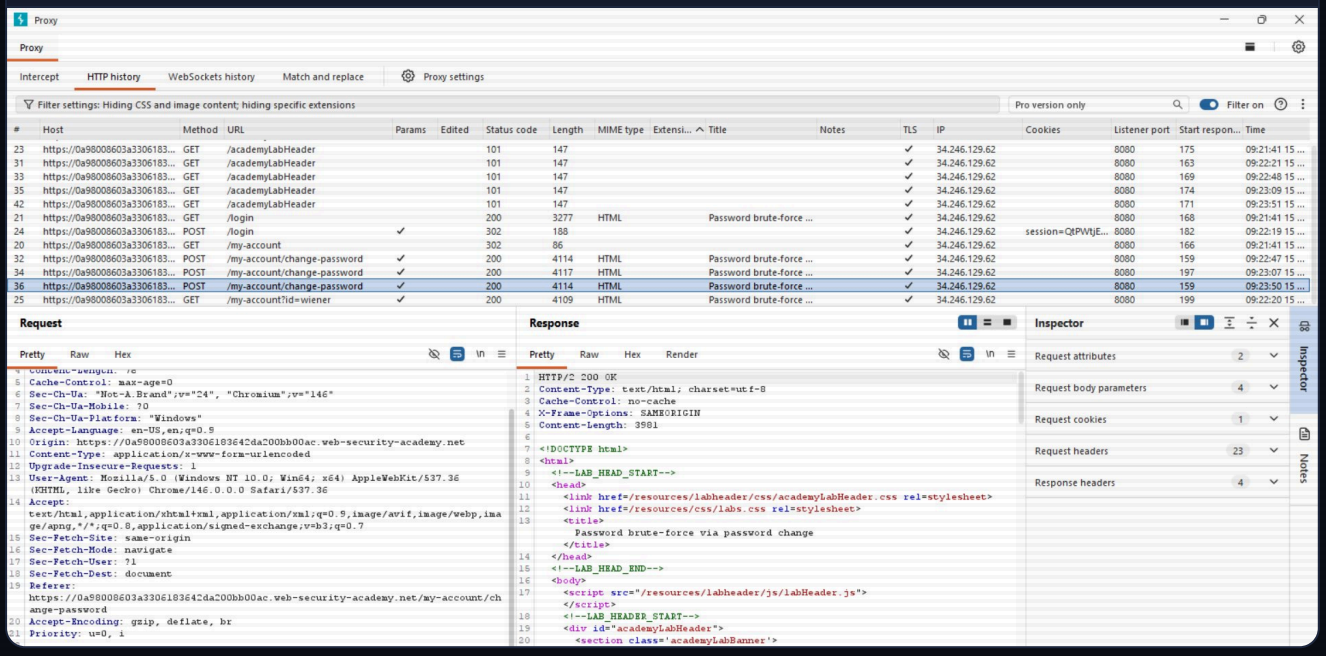


⚠️ **The Vulnerability:** The password change endpoint processes requests for *any* username — including `carlos` — without enforcing session-based ownership. By sending Carlos's username in the POST body with our own session cookie, we can probe his password.

05 Capture the Change-Password Request in Burp Proxy

With Burp Suite running as a proxy, intercept the HTTP history and locate the `POST /my-account/change-password` request. The request body contains `username`, `current-password`, `new-password-1`, and `new-password-2`. Right-click this request and send it to **Intruder**.

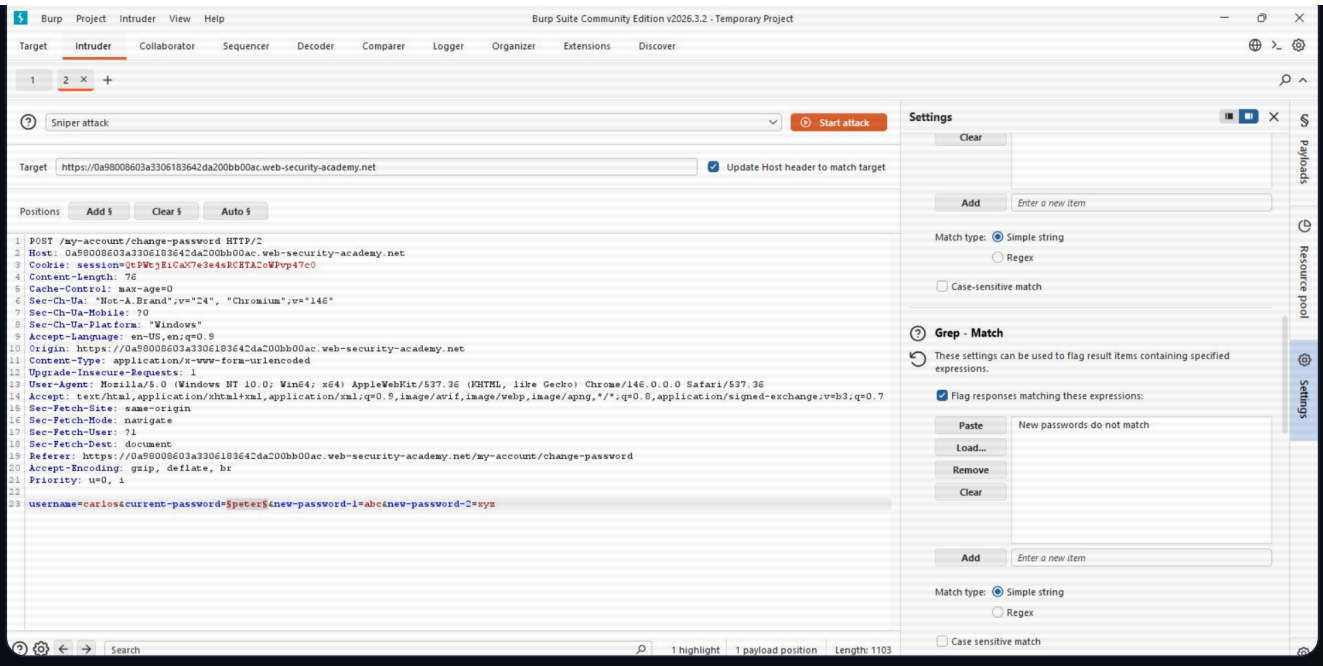
step05.png — Burp Proxy HTTP history



06 Configure Intruder — Positions & Grep-Match

In Burp Intruder, go to the **Positions** tab. Edit the request body to set `username=carlos` and place the payload marker `§peter§` on the `current-password` field. Set `new-password-1=abc` and `new-password-2=xyz` (intentionally mismatched). Then open the **Settings** panel and under *Grep – Match*, add the string `New passwords do not match` — responses flagged with this string indicate the guessed password was correct.

step06.png — Intruder Positions + Grep-Match configured

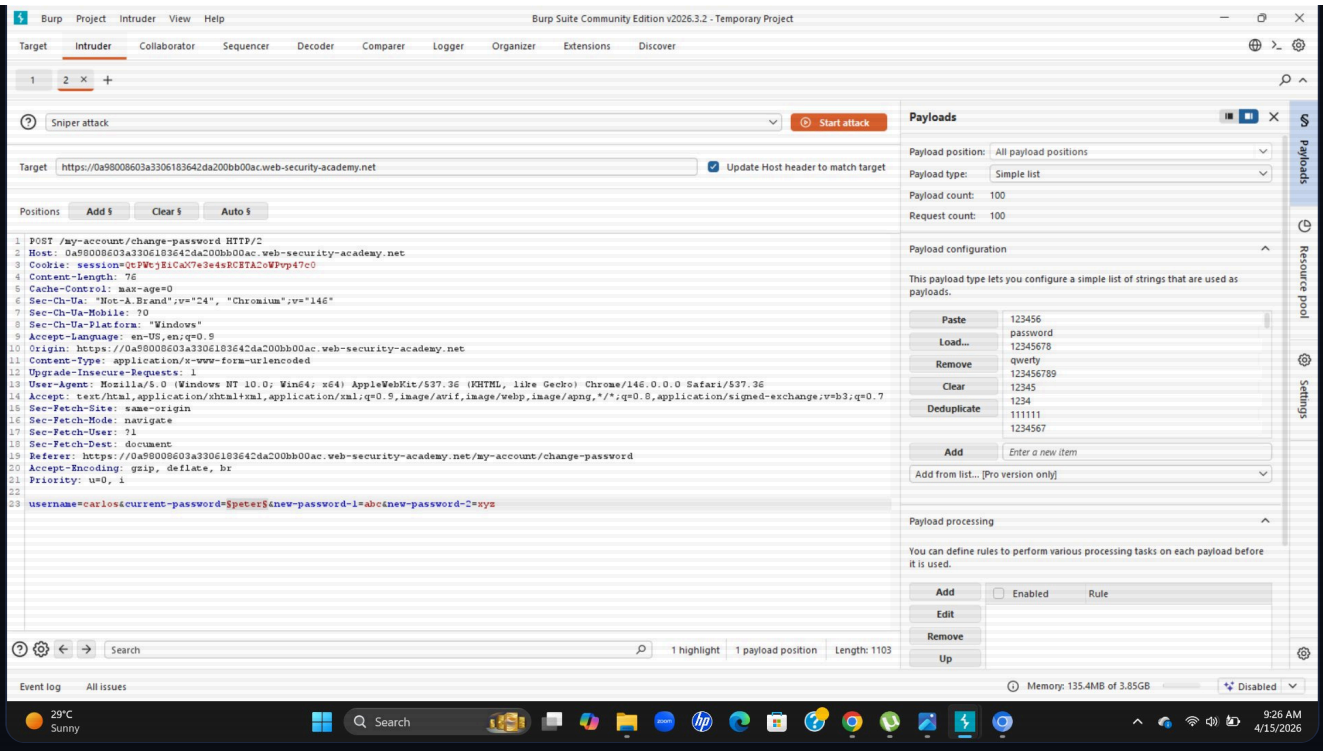


💡 **Why this works:** If the guessed `current-password` is correct for Carlos, the server validates it and then complains that the new passwords don't match — producing our grep string. An incorrect guess produces `Current password is incorrect` instead.

07 Load the Password List as Payloads

Switch to the **Payloads** tab in Intruder. Select *Simple list* as the payload type, then paste or load all 100 candidate passwords from the lab's password list. Burp will substitute each password into the `§peter§` position for every request.

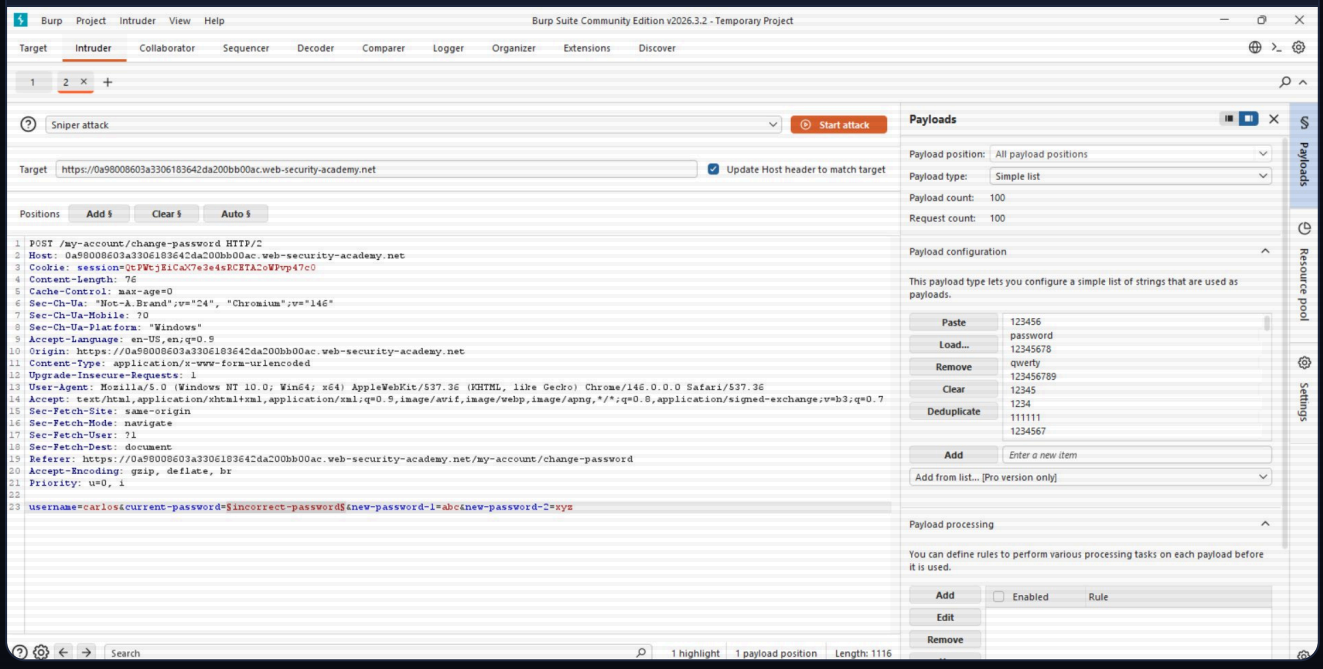
step07.png — Intruder Payloads loaded



08 Verify the Final Intruder Setup Before Attack

Confirm the request body in the Positions tab looks correct: `username=carlos&current-password=§incorrect-password§&new-password-1=abc&new-password-2=xyz`. The payload marker is on `current-password`, username is hardcoded to `carlos`, and new passwords are mismatched. Everything is ready — click **Start attack**.

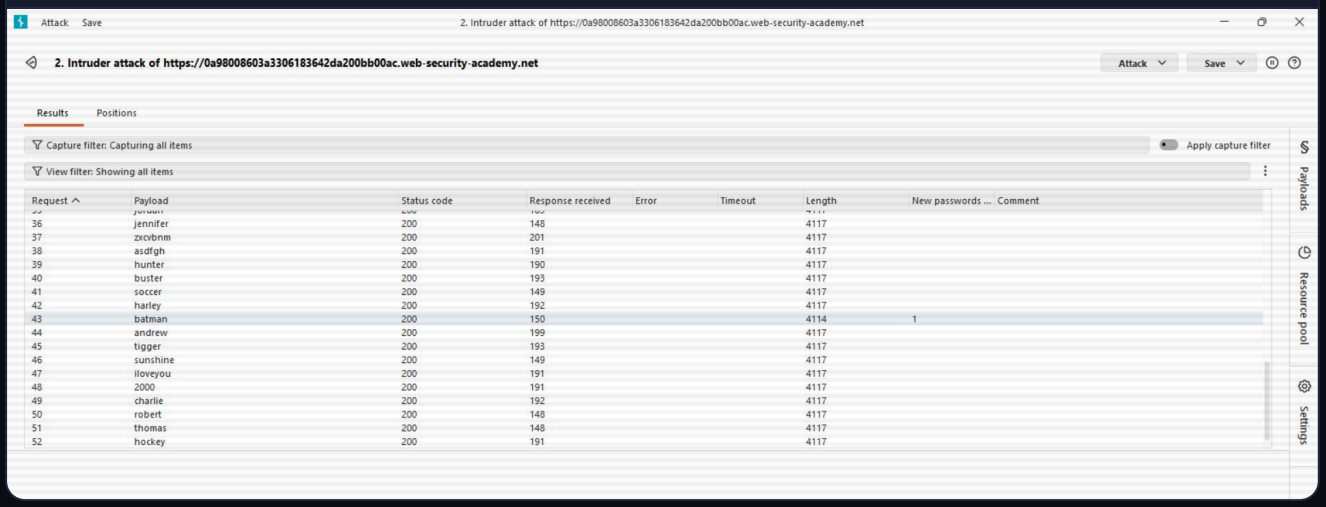
step08.png — Final Intruder setup with $incorrect-password$ marker



09 Analyze Attack Results — Identify the Correct Password

When the attack completes, examine the results table. Sort by the **Length** column or look at the *New passwords do not match* column. **Request #43 with payload** `batman` has a response length of `4114` — slightly different from all other responses at `4117` — and shows a `1` in the grep column, indicating the password change form was actually validated. Carlos's password is **batman**.

step09.png — Attack results: batman flagged at request #43



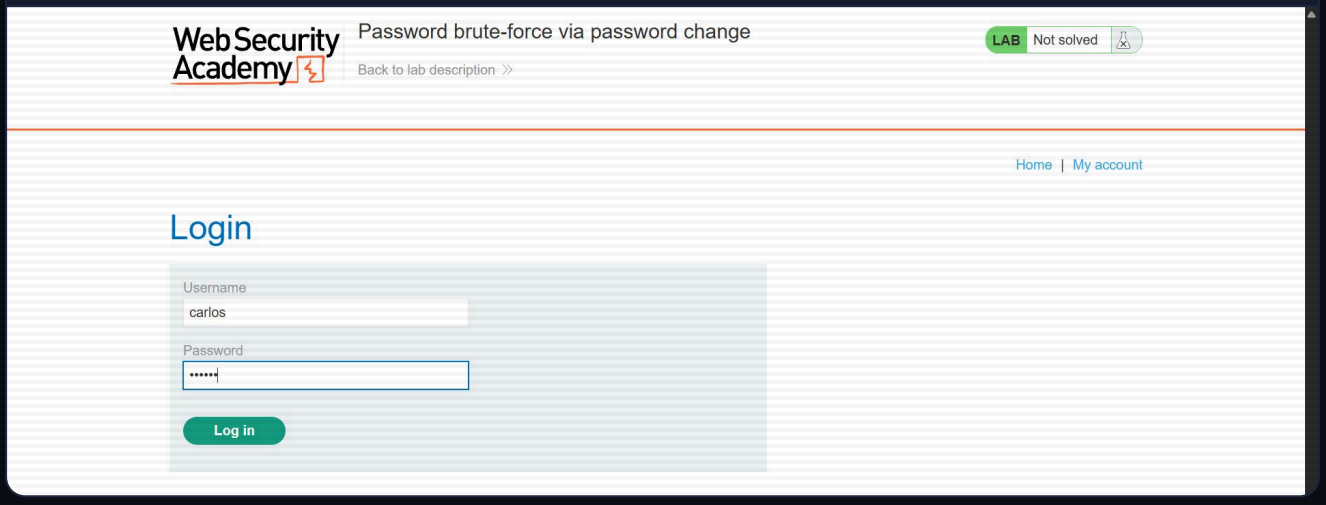
Request	Payload	Status code	Response received	Error	Timeout	Length	New passwords ...	Comment
36	jennifer	200	148			4117		
37	zxcvbnm	200	201			4117		
38	asdfgh	200	191			4117		
39	hunter	200	190			4117		
40	buster	200	193			4117		
41	soccer	200	149			4117		
42	harley	200	192			4117		
43	batman	200	150			4114	1	
44	andrew	200	199			4117		
45	tigger	200	193			4117		
46	sunshine	200	149			4117		
47	iloveyou	200	191			4117		
48	2000	200	191			4117		
49	charlie	200	192			4117		
50	robert	200	148			4117		
51	thomas	200	148			4117		
52	hockey	200	191			4117		

🎯 **Result:** Payload `batman` (request #43) returns length `4114` and a `1` in the grep match column — confirming it matched as the correct current password for Carlos.

10 Log In as Carlos

Return to the login page. Enter `carlos` as the username and `batman` as the password, then click **Log in**.

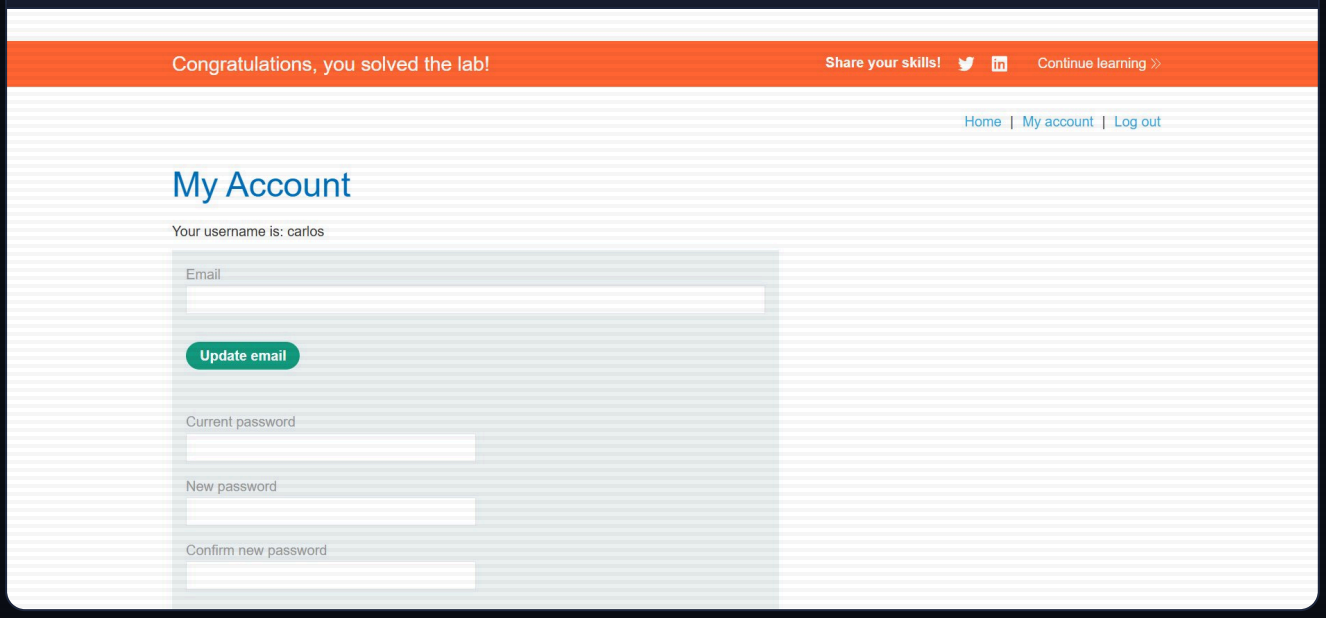
step10.png — Logging in as carlos with discovered password



11 Lab Solved!

Successfully logging into Carlos's account and reaching his My Account page triggers the lab completion banner: **"Congratulations, you solved the lab!"**

step11.png — Lab solved!



🏆

Lab Complete

By exploiting the differing error messages in the password change endpoint — combined with the ability to supply any username in the POST body — we successfully brute-forced Carlos's password without account lockout.

`Authentication Bypass` `Brute Force` `Burp Intruder` `Response Differencing` `Grep-Match` `Password: batman`